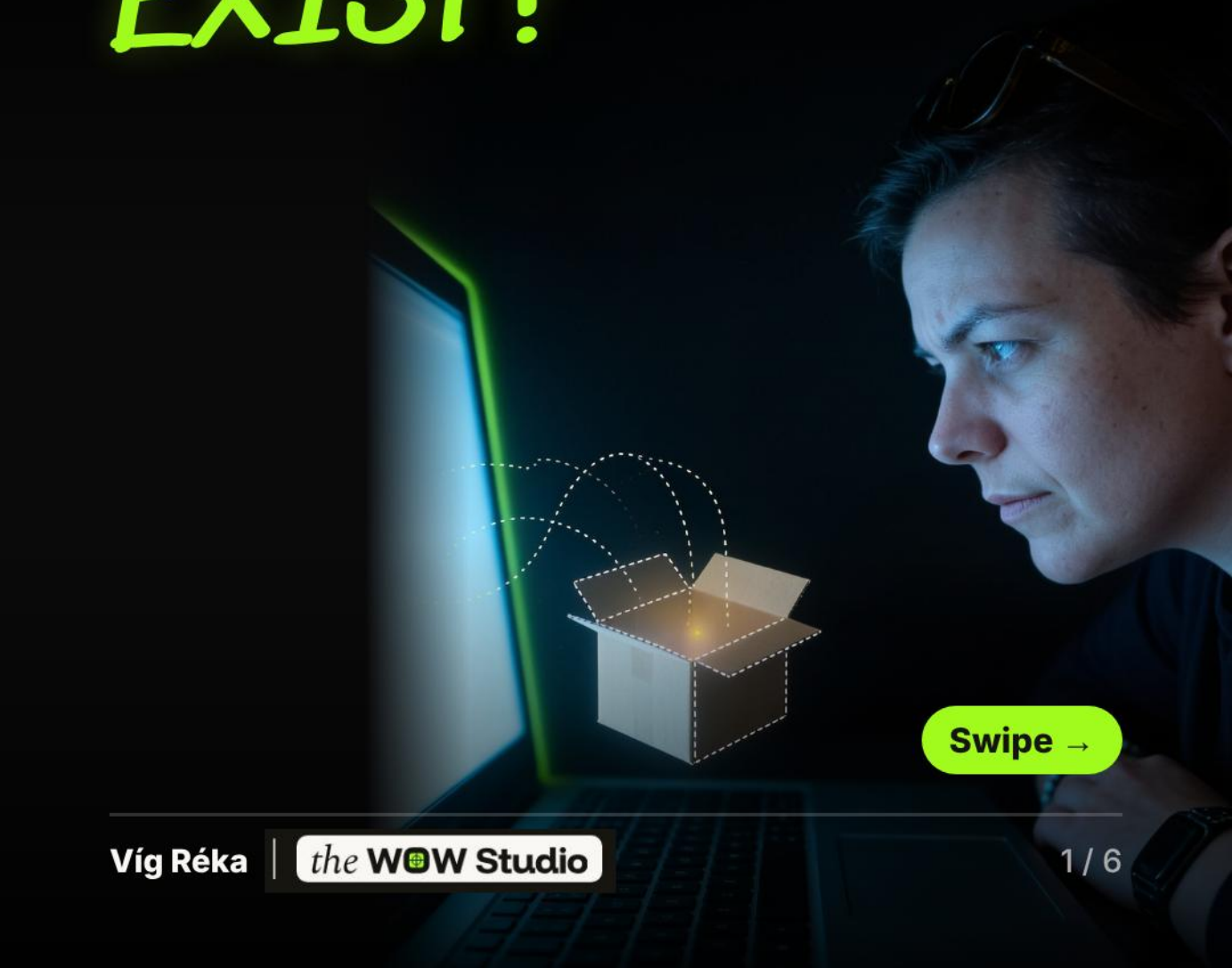
AI · PACKAGES

A PACKAGE THAT DOESN'T EXIST?



Swipe →

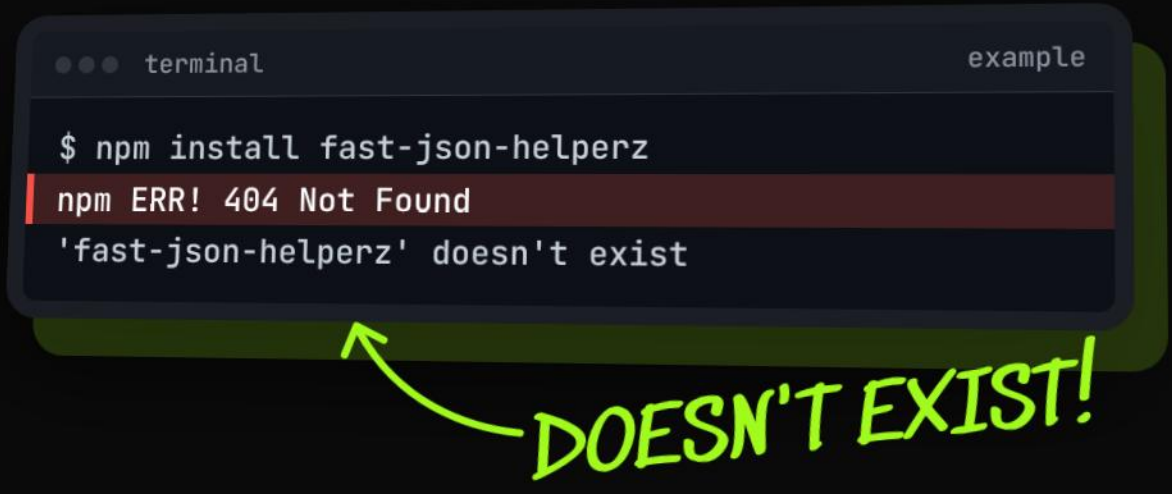
RESEARCH · 2025

02

THE AI MAKES IT UP.

In one study, 16 code-generating AI models wrote 576,000 code samples. 19.7% of the packages they referenced didn't exist: 205,000 unique made-up names.

Spracklen et al. · USENIX Security 2025



IT REPEATS

03

THE SAME *AGAIN.*

For the same prompt, 43% of the made-up packages came back in all 10 runs. Predictable, so it can be exploited.

Spracklen et al. · USENIX Security 2025



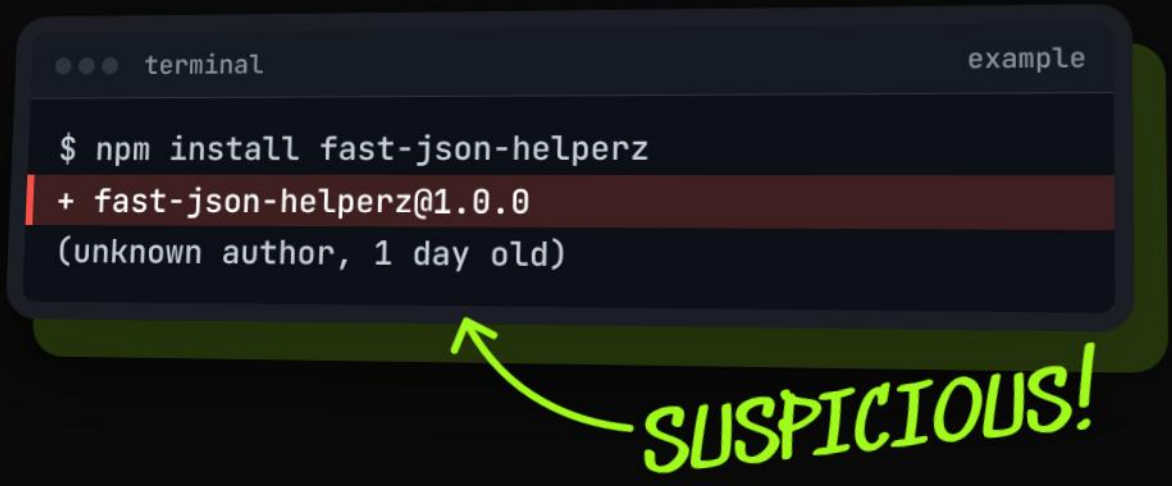
SLOPSQUATTING

04

SOMEONE CLAIMS IT.

If someone registers a made-up name, the next install pulls their package. This is called slopsquatting, a term coined by Seth Larson (Python Software Foundation).

Socket · Apr 8, 2025



THE FIX

05

BEFORE YOU *INSTALL.*

Check that the package exists, who published it and since when. Keep a fixed list of trusted dependencies, and run dependency scanning.

Kaspersky · Socket

1. Exists? Who? Since when?
2. Fixed trusted dependency list
3. Dependency scanning in the pipeline

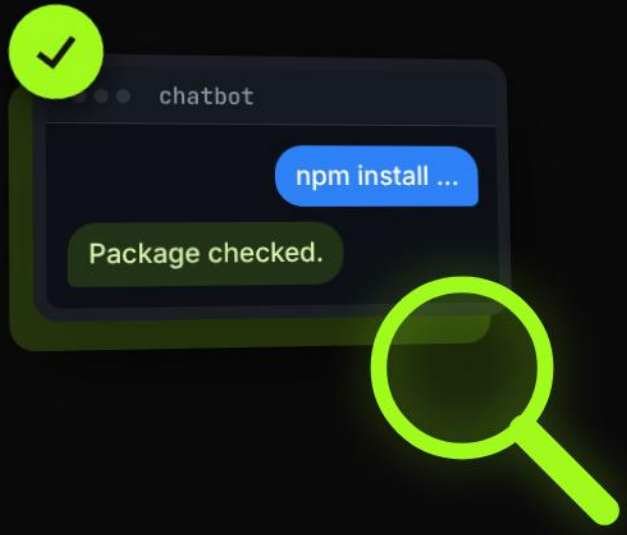
THIS IS KEY!

BUILT YOUR APP WITH AI?

WANT ME TO *TAKE A LOOK?*

I'll check which packages ended up in your app, and where they came from.





Message me →